COMPANION WORKSHEET PACK

Web Application and API Penetration Test

20 worksheets to complete alongside *How to Scope a Web Application and API Penetration Test*.

01	Assessment decision brief	CHAPTER 1
02	Asset register	CHAPTER 2
03	Ownership and authority record	CHAPTER 2
04	Identity and role matrix	CHAPTER 3
05	Tenant test design	CHAPTER 3
06	Critical workflow inventory	CHAPTER 3
07	Coverage module selection	CHAPTER 4
08	API inventory	CHAPTER 4
09	Environment and data plan	CHAPTER 5
10	Dependency boundary	CHAPTER 5
11	Discovery rules	CHAPTER 6
12	Rules of engagement	CHAPTER 7
13	Access readiness checklist	CHAPTER 8
14	Exclusion, limitation, and unknown register	CHAPTER 9
15	Finding acceptance criteria	CHAPTER 10
16	Report acceptance criteria	CHAPTER 10
17	Retest agreement	CHAPTER 11
18	Engagement operating plan	CHAPTER 12
19	Vendor proposal scorecard	APPENDIX B
20	Scope completion record	CHAPTER 13

HOW TO USE THIS PACK

Print the pages you need, or use the editable Word and Excel versions from the same download page. Complete each worksheet against one real product and one real engagement. Chapter references point to the guide, where each worksheet is explained.

© 2026 Sthuthi Technologies, LLC. You may copy these worksheets for internal use within your organization. Educational material only; not legal advice, an audit opinion, or authorization to test any system.

WORKSHEET 01

Assessment decision brief

USE WITH CHAPTER 1

Write the decision the test must support, who relies on it, and what the engagement must not claim.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Engagement name	
Primary business decision	
Trigger for the assessment	
Deadline and reason for it	
People or organizations relying on the output	
Required report or evidence format	
Primary security concern	
Critical data or action at risk	
What a successful engagement must complete	
What the engagement must not claim	
Executive owner	
Technical owner	
Scope version and date	

DECISION QUALITY CHECK

- [ ] The decision names a system or product boundary.
- [ ] The decision names the behavior or security rule under review.
- [ ] The deadline has a real business reason.
- [ ] The relying audience is known.
- [ ] Required deliverables are stated.
- [ ] Success does not depend on finding zero vulnerabilities.

- [ ] The test is not being described as an audit or certification unless it actually is one.

WORKSHEET 02

Asset register

USE WITH CHAPTER 2

One row per component, with an exact identifier and a single scope state.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

ID	Asset or component	Exact identifier	Owner	Environment	Scope state	Allowed test class	Notes
A-01							
A-02							
A-03							
A-04							
A-05							
A-06							

WORKSHEET 03

Ownership and authority record

USE WITH CHAPTER 2

Proof that the person granting authority controls each active target.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Asset ID	Legal or operational owner	Evidence of control	Third-party terms checked	Person granting authority	Status

WORKSHEET 04

Identity and role matrix

USE WITH CHAPTER 3

What each role may read, change, and administer, and whether a test account exists.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Role or identity	Authentication method	Tenant scope	May read	May change	May administer	Test account available
Anonymous	None	None				N/A
Standard customer						
Customer administrator						
Support user						
Platform administrator						
Service identity						

WORKSHEET 05

Tenant test design

USE WITH CHAPTER 3

Synthetic tenants, users, and records for cross-tenant testing.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Tenant	Synthetic users	Synthetic records	Subscription or state	Special relationship	Reset method
Tenant A					
Tenant B					
Parent or reseller					

WORKSHEET 06

Critical workflow inventory

USE WITH CHAPTER 3

The state changes that matter most, each with its expected rule.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

ID	Workflow	Starting role	Sensitive object or action	Expected rule	Failure impact	Priority
W-01						
W-02						
W-03						
W-04						
W-05						

MINIMUM ROLE COVERAGE

- [ ] Anonymous or signed-out behavior
- [ ] Lowest-privilege authenticated user
- [ ] Equivalent users in different tenants
- [ ] Customer or team administrator
- [ ] Internal support or operations role
- [ ] Highest-risk administrative role, if permitted
- [ ] Service or integration identity
- [ ] Suspended, removed, expired, or otherwise changed identity

WORKSHEET 07

Coverage module selection

USE WITH CHAPTER 4

Which coverage modules are included, against which named targets.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Module	Included	Named targets	Required inputs	Highest-priority rule	Material limitation
Web application					
API					
Mobile application					
Cloud configuration					
Connected SaaS or OAuth					
AI-enabled workflow					
Source-code review					
Network or infrastructure					

WORKSHEET 08

API inventory

USE WITH CHAPTER 4

Every API version, base URL, specification, and authentication scheme.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

API or version	Base URL	Specification	Authentication	Roles	Object types	Webhooks or callbacks	Scope state

WORKSHEET 09

Environment and data plan

USE WITH CHAPTER 5

Where testing runs, with what data, and how it is reset.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Primary test environment	
Exact release or build	
Known differences from production	
Production confirmation allowed	
Synthetic tenants and records	
Prohibited data classes	
Evidence storage location	
Client-visible redaction rule	
Raw evidence retention period	
Test data deletion owner and date	
Reset or rollback method	

WORKSHEET 10

Dependency boundary

USE WITH CHAPTER 5

Where testing stops at each third-party dependency.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Dependency	Purpose	Owner	Test mode	Allowed interaction	Prohibited interaction	Contact
Identity provider						
Email or messaging						
Payment service						
File processing						
Model or AI service						
Customer webhook						

WORKSHEET 11

Discovery rules

USE WITH CHAPTER 6

What testers may look for, and what happens when they find something new.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Discovery activity	Allowed	Boundary	Active requests allowed	Rate limit	New-target action
Certificate and public-record review			N/A	N/A	
DNS and subdomain enumeration					
Host and port identification					
Content and route discovery					
JavaScript and mobile endpoint review					
Cloud resource discovery					
API inventory comparison					

WORKSHEET 12

Rules of engagement

USE WITH CHAPTER 7

The signed permissions and constraints for active testing.

PRODUCT OR DEAL

PREPARED BY

DATE

Contracting client	
Target owner or owners	
Person granting authority	
Testing provider and test lead	
Scope version incorporated by reference	
Active testing start	
Active testing end	
Time zone	
Blackout periods	
Source addresses or identifiers	
Maximum request rate or concurrency	
Allowed automated tools or classes	
Allowed data-changing actions	
Prohibited actions	
Stop conditions	
Emergency client contact	
Emergency assessor contact	
Evidence and data-handling terms	
Provider policies checked	
Client approval and date	

Assessor acceptance and date	

AUTHORIZATION RELEASE CHECK

- [ ] Every active target has a proved owner.
- [ ] The approver can grant authority for those targets.
- [ ] Third-party and cloud-provider conditions were checked.
- [ ] Allowed and prohibited actions are explicit.
- [ ] Dates, times, time zone, and source addresses are recorded.
- [ ] Rate and cost limits are recorded.
- [ ] Stop contacts and conditions are tested or confirmed.
- [ ] The signed authorization references the same scope version the assessor will use.

WORKSHEET 13

Access readiness checklist

USE WITH CHAPTER 8

Accounts, keys, documents, and contacts ready before day one.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Item	Owner	Ready	Secure delivery method	Expiry or reset	Notes
Tenant A standard user					
Tenant A administrator					
Tenant B standard user					
Tenant B administrator					
Internal support role					
API client or key					
Mobile test build					
Cloud read access					
Architecture and data flow					
API specification					
Logging and alert contact					
Reset and cleanup process					

WORKSHEET 14

Exclusion, limitation, and unknown register

USE WITH CHAPTER 9

Everything the test will not cover, and why.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

ID	Type	Description	Reason	Coverage effect	Decision owner	Resolution or report wording
L-01						
L-02						
L-03						
L-04						

WORKSHEET 15

Finding acceptance criteria

USE WITH CHAPTER 10

What every reported finding must contain.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Requirement	Mandatory	Report location or format	Reviewer
Plain-language title			
Affected target and release			
Expected rule			
Reproduction steps			
Sanitized evidence			
Material impact			
Severity and rationale			
Recommended correction			
Owner and state			
Retest evidence			

WORKSHEET 16

Report acceptance criteria

USE WITH CHAPTER 10

What the final report must contain before it is accepted.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Report audiences	
Required executive summary	
Technical detail level	
Severity method	
Required compliance or framework mapping	
Evidence sanitization rule	
Report classification	
Authorized recipients	
Draft review period	
Final delivery date and format	
Customer-shareable output	
Report retention and deletion	

WORKSHEET 17

Retest agreement

USE WITH CHAPTER 11

Retest units, timing, evidence, and commercial terms.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Included retest rounds	
Retest availability period	
Required notice	
Client evidence required before scheduling	
Corrected release identifier	
Environment	
Original scenarios to repeat	
Regression checks included	
Treatment of partial fixes	
Treatment of new findings	
Verification approver	
Updated report format	

WORKSHEET 18

Engagement operating plan

USE WITH CHAPTER 12

Contacts, decision points, and the working rhythm of the test.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Milestone or responsibility	Owner	Backup	Date or service target	Channel	Acceptance evidence
Scope approval					
Authorization complete					
Access verification					
Testing start					
Routine status update					
Critical issue escalation					
Draft report					
Factual review close					
Final report					
Retest request					

WORKSHEET 19

Vendor proposal scorecard

USE WITH APPENDIX B

Score each criterion 0–3 and multiply by the weight. Never select a provider on the total alone.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Criterion	Weight	Vendor A	Vendor B	Vendor C	Evidence or concern
Scope reflects named systems and workflows	5				
Manual authorization and business-logic testing	5				
Qualified named test lead and reviewer	4				
Clear rules of engagement	5				
Evidence and reproduction quality	5				
Report serves engineers and executives	4				
Data handling and retention	5				
Retesting terms	4				
Schedule and access dependencies	3				
Transparent exclusions and assumptions	4				
Price and change-control terms	3				
Relevant application or industry experience	3				

WORKSHEET 20

Scope completion record

USE WITH CHAPTER 13

Final sign-off for the issued scope version. Keep it with the signed authorization.

PRODUCT OR DEAL _____ PREPARED BY _____ DATE _____

Organization	
Product or system	
Scope version	
Prepared by	
Reviewed by	
Approved by	
Authorization reference	
Date issued	
Next review date	